

C&S Wholesale Grocers, Inc. and Subsidiaries

Policy Title: Information Services Security Policy
Status: Active
Policy Owner: IS Security and Compliance
Original Issue Date: 10/03/2012

SOP# CSISSD004
Version: 3.0
Department: IT
Last Review: 11/24/2025

Document History

Document Revision	Reviewer	Description of Changes	Date
1	Diptanil Paul	Annual Review	07/30/2022
2	Sarah Ward	Document History table added Table of Contents added	3/23/2023
3	Diptanil Paul	Annual Review	08/01/2023
4	Diptanil Paul	Annual Review	09/25/2024
5	Diptanil Paul	Annual Review	11/24/2025

C&S Wholesale Grocers, Inc. and Subsidiaries

Table of Contents

Document History..... 1

1. Purpose 3

2. Management Responsibilities..... 3

3. Information Security Policy..... 3

 3.1. Information Security Program Management 3

 3.2. Information Security Requirements for Company Systems and Applications 3

4. Roles and Responsibilities..... 5

5. Definitions 5

6. Related Documents 6

C&S Wholesale Grocers, Inc. and Subsidiaries

1. Purpose

To protect the confidentiality, integrity, availability, and privacy of Company information and information assets while maintaining appropriate levels of accessibility by providing the framework for the:

- Development and maintenance of the security requirements for Company information systems and networks
- Implementation and update of controls to meet and verify security requirements
- Delineation of responsibilities and expected behavior for all individuals accessing the systems

2. Management Responsibilities

It is the manager's responsibility to ensure that his/her direct-report employees, interns, contractors, and/or third-party workers are aware of, and agree to abide by, the Company's Information Security requirements.

3. Information Security Policy

In the course of carrying out Company objectives, Workforce Members may be given access to many different types of information or information systems including those of our customers or business partners. These information assets, including the systems that are used to handle them, are important resources to the Company. Any person who accesses Company Information or Information Systems has a responsibility to maintain and protect these resources. Failure to protect these resources could result in significant harm to the Company, including damaging the ability for the Company to receive/enter orders, receive/ship product, bill/receive payment, or pay its employees. In addition, many laws and regulations, and terms of certain contracts with our customers and business partners also require the Company to protect the confidentiality, integrity and availability of these information assets.

3.1. Information Security Program Management

The Company shall appoint appropriately qualified personnel that shall have responsibility for the management of a Information Security program and implementation of the necessary administrative, technical, and physical safeguards appropriate to:

- The risks to the business
- Generally accepted information security practices
- Applicable legal and regulatory requirements for data protection as defined by the Company's Legal team

Below are the Company Information Security principles:

3.1.1. Information Security Governance

Information security policies, standards, guidelines and procedures shall be developed to communicate security requirements and guide the selection and implementation of security control measures.

3.1.2. Roles and Responsibilities

Personal accountability and responsibility for information security shall be incorporated in roles and responsibilities to ensure that every individual applies the applicable information security policies, principles, procedures and practices in their daily work-related activities.

3.1.3. Security Awareness

Workforce Members shall receive security education, training and awareness programs to ensure that they are aware of security threats and concerns and are equipped to apply organizational security policies and principles.

3.1.4. Asset Management

Information assets shall be classified according to their criticality to the organization enabling an appropriate level of protection.

3.1.5. Acceptable Use

Information assets are to be used for the intended business purpose only.

3.1.6. Compliance

Legal, regulatory and contractual requirements shall be identified, documented, and incorporated into the Information Security program when applicable.

3.2. Information Security Requirements for Company Systems and Applications

Company Systems or Applications that access, store, process, transmit, or dispose of Company Confidential Information shall adhere to the following data protection requirements:

C&S Wholesale Grocers, Inc. and Subsidiaries

3.2.1. Risk Management

Risks shall be identified, measured, monitored, and controlled to reduce risk to a reasonable and appropriate level.

3.2.2. Malware Protection/Integrity Monitoring

Systems and applications shall be protected against malicious software or unauthorized changes.

3.2.3. Secure Configuration

Systems and applications shall be hardened according to information security best practices, including the elimination of any common "default" settings that introduce unnecessary risk.

3.2.4. Application Security

Security shall be integrated into the development lifecycle to ensure developers produce secure code, perform code reviews, and adhere to coding best practices.

3.2.5. Vulnerability Assessments

Systems and applications shall undergo periodic vulnerability assessments in order to detect vulnerabilities and configuration weaknesses.

3.2.6. Patching

Systems and applications shall be regularly updated and patched to mitigate vulnerabilities.

3.2.7. Logging

Systems and applications shall record and retain the necessary logs to support the investigation of security incidents, access reviews, or the detection of malicious or anomalous activity.

3.2.8. Security Incident and Breach Response

A security incident and breach response plan shall exist to facilitate the response to suspected or known security incidents; mitigate the harmful effects of security incidents, and document and report security incidents to the appropriate parties.

3.2.9. Encryption

Where reasonable and appropriate, all Confidential Information shall be encrypted during storage and transmission using industry accepted encryption algorithms.

3.2.10. Access Controls

Workforce Members will only be granted the access that is required to perform their role. IS leadership will identify critical systems that will undergo periodic access reviews to ensure access is removed when no longer needed. All access shall be removed upon termination of employment.

3.2.11. Communications Security

The Confidentiality, Integrity, and Availability of Confidential Information passing over public networks, over wireless networks or the physical network, shall be protected.

3.2.12. Change Management

Changes to production services, systems, and their associated components shall be recorded, evaluated, authorized, prioritized, planned, tested, implemented, documented and reviewed in a controlled manner

3.2.13. Mobile Device Management

Risks introduced by using company provided or personal mobile devices shall be managed.

3.2.14. Third Party Access to Company Systems

Risks introduced by granting 3rd parties access to the Company network or Company systems shall be managed.

3.2.15. Business Continuity/Disaster Recovery

A Business Continuity/Disaster Recovery ("BC/DR") plan and program that is appropriate to the business shall exist to achieve continuity of operations for mission critical functions in the event of an emergency or disaster.

3.2.16. Office and Data Center Security

The Company shall implement physical safeguards (appropriate to the facility and data housed) to prevent unauthorized physical access, damage, theft, or interference to Company operations.

C&S Wholesale Grocers, Inc. and Subsidiaries

3.2.17. Workspace Security

The Company shall maintain and enforce policies to ensure Confidential Information or Company Information Systems remain secure while unattended.

3.2.18. Asset Management

An up-to-date inventory of Information Services assets shall be developed and maintained in accordance with Company Information Security policies. Application systems identification items shall include, but are not necessarily limited to the following:

- Application system name and ID;
- Responsible organization(s);
- Contact information;
- Operational status;
- Description and purpose;
- Interconnections and information sharing;
- Applicable regulations;
- Information sensitivity

3.2.19. Security Assessments

Security assessment of the Company's Information Services network and assets shall be conducted periodically to assess deficiencies and/or improve security. Any significant deviation from the Information Services Security Policies shall require that the Director of Information Security and Compliance convene an Information Services Leadership meeting to consider remediation or changes to the Information Security policy, if required.

3.2.20. External Review

At least once every three years, the Company shall participate in an external review (audit) to verify its compliance with the Information Services Security Policies and help evaluate the program's effectiveness.

4. Roles and Responsibilities

Role	Responsibility
Manager Information Services Security and Compliance	The principal contact point on matters pertaining to information security and adherence to established controls and processes for safeguarding Company information. He or she interfaces with Business systems owners and their Information Services counterparts in ensuring that adequate protection and security safeguards are in place and functioning. In this capacity he or she is responsible for developing, overseeing the implementation of, updating, monitoring, and periodically reporting on the Information Services Security Plan.
Information Services Leadership	The managerial hierarchies within Information Services that interfaces with Business owners of Company systems and the Manager, Information Services Security and Compliance to ensure that controls and access points are clearly defined and rigorously enforced. The Information Services Leadership Team provides input to the Information Services Security Plan for their respective areas, and in concert with Human Resources and Business system owners, establishes/coordinates user training programs for information systems. Senior IS Leadership reviews and approves the Information Services Security Plan and updates thereto.
System Owner	The Business executive with primary responsibility for a particular Company system or series of subsystems. Complex systems may be parsed into a collection of subsystems to correlate with corresponding business processes and owners. The system owner is the primary focal point for the determination of system roles and separation of duties.

5. Definitions

Term	Definition
Information Security	An established set of rules, regulations, policies, procedures, and processes designed to safeguard the intellectual resources of a corporate body or entity.
Information Services Security Plan	A documented strategy for safeguarding an organization's body of knowledge to ensure that it is protected from unauthorized internal or external resources that might seek to profit from such information at the expense of the organization or harm the organization through malicious intent.

C&S Wholesale Grocers, Inc. and Subsidiaries

Term	Definition
Security breach	The compromise of one or more elements of an information system, the exposure of which jeopardizes an organization's primary function(s) and/or subjects it to unnecessary risk or legal consequences.
Security Role	An established set of rules and access points within a system granted to a position so that the incumbent may exercise the responsibilities necessary to perform the duties of said position.
Separation of Duties	The conscious deconstruction and partitioning of organizational processes to preclude the possibility of individuals having the ability to influence such processes for personal gain or enrichment.

6. Related Documents

None.